

ACTIVIDAD A08

INFORME PROFESIONAL DE PENTESTING

Cliente simulado: INSECUR S.A.
Plataforma de laboratorio: TryHackMe

Campo	Valor
Estudiante	Tomás Velazquez
DNI	45257430
Username TryHackMe	TomiVel
Correo de contacto	tomiveltorres@gmail.com
Salas	Pentesting Fundamentals, Basic Pentesting, Vulniversity
Branch	velazquez-tomas
Inicio / cierre	07/10/2026 - 08/10/2026
Estado	VERSIÓN FINAL PARA REVISIÓN Y FIRMA

Informe del laboratorio con bitácoras y capturas incorporadas. Antes de entregar, firmar la declaración ética y verificar la identidad visible en las evidencias críticas.

1. Contexto, objetivo y resumen ejecutivo

INSECUR S.A. contrata, en el escenario académico planteado por la cátedra, una evaluación de seguridad de laboratorio orientada a identificar exposiciones, debilidades de autenticación y configuraciones susceptibles de abuso, así como a proponer salvaguardas y medidas de continuidad del negocio.

Las pruebas se limitaron a las salas autorizadas de TryHackMe. Se completaron las salas Pentesting Fundamentals, Basic Pentesting y Vulniversity. En los ejercicios prácticos se observaron rutas expuestas, recursos compartidos accesibles sin autenticación adecuada, debilidades vinculadas a SSH y ejecución de código en el servidor web de Vulniversity; esta última permitió demostrar ejecución de comandos con privilegios elevados por una configuración SUID insegura.

Alcance de la conclusión: el impacto es comprobado o inferido únicamente respecto de los laboratorios. No representa un diagnóstico de infraestructura real de INSECUR S.A.

2. Pre-pentesting

2.1. Alcance autorizado

Dentro del alcance: salas Pentesting Fundamentals, Basic Pentesting y Vulniversity; máquinas efímeras e IP asignadas por la plataforma en cada sesión. Fuera del alcance: sistemas de terceros, activos reales de empresas, otras salas y dispositivos ajenos a la autorización académica.

2.2. Reglas de enfrentamiento (ROE)

Realizar pruebas exclusivamente mientras el laboratorio esté autorizado y activo; limitar la intensidad del tráfico; evitar denegación de servicio, daños deliberados y persistencia innecesaria; registrar comandos y resultados; no difundir credenciales, claves privadas ni flags en texto claro; suspender la actividad si se detecta un comportamiento no previsto o se pierde la certeza del alcance.

Los horarios y límites cuantitativos específicos de tráfico no constan en la información disponible: pendiente confirmar con la cátedra si existen restricciones adicionales.

2.3. Autorización y metodología

La autorización académica descrita en la Guía A08 abarca únicamente las salas previstas. Se siguió un flujo alineado con las fases de NIST SP 800-115 y las etapas prácticas especificadas por la guía: planificación y alcance; reconocimiento; escaneo; enumeración; explotación controlada; post-explotación; documentación y remediación. La referencia metodológica se utiliza para estructurar el trabajo, no para afirmar una certificación formal.

2.4. Herramientas empleadas

Kali Linux en VirtualBox; OpenVPN para el acceso al laboratorio; Nmap para enumeración de puertos y servicios; Gobuster para enumeración de rutas; SMB y SSH para revisión de accesos; Hydra y John the Ripper en ejercicios autorizados de Basic Pentesting; Burp Suite Intruder para verificar extensiones de subida; Netcat para constatar la conexión remota; comandos Linux y systemctl para pruebas de privilegios.

3. Desarrollo por sala

3.1. Pentesting Fundamentals

Sala metodológica: reconocimiento de las fases, reglas de enfrentamiento, autorización, ejecución técnica y presentación profesional de resultados. No se atribuye a esta sala la explotación de una máquina ni el hallazgo de una CVE.

3.2. Basic Pentesting

Objetivo identificado en el registro de Nmap: 10.64.138.62 (IP efímera de laboratorio). Escaneo: SSH/22 OpenSSH 8.2p1; HTTP/80 Apache 2.4.41; SMB/139 y 445 Samba; AJP/8009; HTTP/8080 Apache Tomcat 9.0.7. El escaneo también indicó que la firma SMB estaba habilitada pero no era obligatoria. Se detectó /development/ con Gobuster; se consultaron recursos SMB accesibles anónimamente; y se validaron debilidades de autenticación y gestión de material SSH dentro de la sala.

3.3. Vulnversity

Escaneo reproducido y guardado el 08/10/2026 para la IP efímera 10.65.161.75: 65.535 puertos TCP revisados, 3128/tcp Squid 4.10 y 3333/tcp Apache 2.4.41 (Ubuntu). Gobuster había detectado /internal/ en una sesión anterior. Las direcciones IP cambiaron entre reinicios de la máquina; no deben confundirse capturas de sesiones diferentes.

En la zona de subida, las pruebas controladas rechazaron .php y aceptaron .phtml. Se constató ejecución de PHP y una sesión como www-data (UID 33). Luego se encontró /bin/systemctl con permiso SUID 4755. Un servicio temporal ejecutó id con el resultado uid=0(root) gid=0(root) groups=0(root). Este resultado prueba ejecución privilegiada del servicio; no implica que la reverse shell haya cambiado de usuario.

4. Hallazgos técnicos por fase

H-01 - Exposición de directorio /development/ (Medio)

Fase: Enumeración. Componente: Basic Pentesting; Apache HTTP. Categoría: CWE-200 (orientativo). CVE: no atribuida con evidencia suficiente. Impacto CIA: Confidencialidad.

Evidencia a asociar: Gobuster; rutas y archivos de desarrollo. Salvaguarda propuesta: Restringir publicación y acceso a archivos internos. Riesgo residual estimado tras aplicar: Bajo.

H-02 - Acceso anónimo a recurso SMB (Medio)

Fase: Enumeración. Componente: Basic Pentesting; recurso compartido Samba. Categoría: CWE-284 (orientativo). CVE: no atribuida con evidencia suficiente. Impacto CIA: Confidencialidad.

Evidencia a asociar: Acceso a staff.txt sin autenticación; verificar registros. Salvaguarda propuesta: Deshabilitar acceso invitado; ACL y auditoría. Riesgo residual estimado tras aplicar: Bajo.

H-03 - Credenciales SSH débiles en laboratorio (Alto)

Fase: Explotación. Componente: Basic Pentesting; SSH. Categoría: CWE-521 (orientativo). CVE: no atribuida con evidencia suficiente. Impacto CIA: Confidencialidad, integridad.

Evidencia a asociar: Validación con Hydra en sala autorizada; NO publicar contraseña. Salvaguarda propuesta: Frases de paso robustas; MFA; límites de intentos. Riesgo residual estimado tras aplicar: Medio.

H-04 - Clave privada SSH expuesta por permisos de lectura (Alto)

Fase: Explotación. Componente: Basic Pentesting; material SSH de usuario. Categoría: CWE-732 (orientativo). CVE: no atribuida con evidencia suficiente. Impacto CIA: Confidencialidad, integridad.

Evidencia a asociar: Archivo id_rsa accesible y passphrase recuperada en ejercicio. Salvaguarda propuesta: Permisos 600; rotación de claves y protección de cuentas. Riesgo residual estimado tras aplicar: Bajo.

H-05 - Carga de .phtml y ejecución de código PHP (Crítico)

Fase: Explotación. Componente: Vulnversity; /internal/; web 3333. Categoría: CWE-434. CVE: no atribuida con evidencia suficiente. Impacto CIA: Confidencialidad, integridad, disponibilidad.

Evidencia a asociar: Burp Intruder: .php rechazado y .phtml aceptado; shell www-data. Salvaguarda propuesta: Lista permitida estricta; almacenamiento fuera de webroot; bloquear ejecución. Riesgo residual estimado tras aplicar: Medio.

H-06 - SUID indebido sobre /bin/systemctl (Crítico)

Fase: Post-explotación. Componente: Vulniversity; systemctl. Categoría: CWE-250 / CWE-269 (orientativo).
CVE: no atribuida con evidencia suficiente. Impacto CIA: Confidencialidad, integridad, disponibilidad.

Evidencia a asociar: Permiso 4755 y salida id: uid=0(root). Salvaguarda propuesta: Quitar SUID innecesario; revisar privilegios y unidades systemd. Riesgo residual estimado tras aplicar: Bajo.

Nota de evaluación: las severidades son cualitativas y provisionales; no se calculó una puntuación numérica CVSS. Las categorías CWE indicadas como orientativas deberán validarse contra la evidencia final.

5. Resumen ejecutivo de hallazgos

Severidad	Cantidad	IDs
Crítico	2	H-05, H-06
Alto	2	H-03, H-04
Medio	2	H-01, H-02
Bajo	0	-
Total	6	H-01 a H-06

6. Recomendaciones post-pentesting

6.1. Técnicas priorizadas

Prioridad inmediata: impedir ejecución de scripts en directorios de subida, validar archivos por contenido y lista permitida de extensiones, revisar la configuración de Apache/PHP; retirar SUID de /bin/systemctl cuando no corresponda y auditar servicios systemd. Alta prioridad: proteger claves SSH, rotar credenciales posiblemente expuestas, reforzar autenticación y deshabilitar acceso SMB anónimo. Prioridad complementaria: retirar archivos de desarrollo publicados y revisar configuraciones de permisos y monitoreo.

6.2. Administrativas

Política de mínimo privilegio; gestión formal de cambios; procedimiento de publicación segura de aplicaciones; inventario de activos; revisión trimestral de accesos y permisos; capacitación sobre credenciales y secretos; registros centralizados; simulacros de respuesta y pruebas de restauración de copias de seguridad.

7. Protocolo de contingencia (propuesta para escenario simulado)

7.1. Escenario y alcance del impacto

Escenario: explotación de subida de archivos que permite ejecutar código web y, mediante una configuración de privilegios errónea, realizar cambios administrativos o interrumpir el servicio. En un entorno productivo análogo, podrían verse afectadas la atención web, datos operativos y procesos dependientes del servidor. No se dispone de métricas reales de INSECUR S.A.; todos los tiempos siguientes son objetivos sugeridos para validar mediante análisis de impacto de negocio (BIA).

7.2. Activación y primera respuesta

Detección: alerta de carga sospechosa, ejecución inesperada de PHP, alteraciones de unidades systemd, monitoreo de integridad, anomalías en logs o caída del servicio. Primeros 15 minutos: abrir incidente, preservar registros y trazas, aislar la instancia afectada o limitar tráfico, suspender cargas de archivos y escalar a seguridad/operaciones. Evitar reinicios o eliminaciones precipitadas que destruyan evidencia.

7.3. Recuperación, comunicación y post-mortem

Recuperación: desplegar una instancia conocida como íntegra desde infraestructura confiable; recuperar datos desde backups verificados; aplicar los controles de carga y permisos; rotar credenciales y claves; verificar integridad, funcionalidad y monitoreo antes de abrir al público. Comunicación: responsables de TI, seguridad y dirección; usuarios y terceros según alcance y obligaciones aplicables. Post-mortem: línea de tiempo, causa raíz, impacto, lecciones aprendidas, acciones y responsables.

7.4. Objetivos de continuidad estimados

Indicador	Valor propuesto	Condición
RTO	4 horas	Objetivo preliminar, no medido
RPO	1 hora	Requiere backups suficientemente frecuentes y restauración probada

Estos objetivos son supuestos de diseño y deben ser aprobados por la organización mediante BIA; no fueron exigidos ni verificados en TryHackMe.

8. Anexos y trazabilidad de evidencias

A. Bitácoras

bitacora/nmap_inicial.txt; bitacora/gobuster.txt; bitacora/vulniversity_nmap.txt; bitacora/vulniversity_gobuster.txt. Las cuatro rutas corresponden a archivos observados en Kali, no adjuntos automáticamente a este PDF.

B. Capturas incorporadas en el Anexo B

evidencias/escaneo/escaneo_H01.png; evidencias/escaneo/escaneo_H02.png; evidencias/reconocimiento/reconocimiento_H03.png; evidencias/reconocimiento/reconocimiento_H04.png. Debe verificarse la legibilidad y, en capturas críticas, la presencia del username THM, fecha/hora e IP de objetivo según la guía.

C. Descripciones técnicas

evidencias/explotacion/vulniversity_hallazgo.txt y evidencias/post/vulniversity_escalada.txt. Son registros descriptivos posteriores, no capturas contemporáneas de la explotación.

D. Hashes SHA-256 de flags

Vulniversity, root flag, SHA-256: cfbcb740435ad60030304080e35131ffcaf8ac5f71b65e002f5b546aa3cda7ce8

La contraseña final de Basic Pentesting no se publica; no es una flag de la sala.

E. Declaración ética

Declaro que todas las actividades se realizaron dentro del alcance autorizado, en entornos controlados y con fines exclusivamente académicos.

Firma del estudiante: _____ Fecha: _____

9. Bibliografía de base

Guía + Plantilla A08 - INSECUR S.A., Seguridad Aplicada a Sistemas de Información, cátedra Universidad Champagnat. TryHackMe: Pentesting Fundamentals, Basic Pentesting y Vulniversity. NIST SP 800-115, Technical Guide to Information Security Testing and Assessment. OWASP Web Security Testing Guide. Las referencias externas se mencionan como marcos de consulta, sin aseverar que se hayan consultado nuevas fuentes

ANEXO B — EVIDENCIAS GRÁFICAS

Capturas incorporadas a partir del paquete evidencias_A08.zip enviado por el estudiante. Representan visualizaciones de resultados guardados en Kali. No deben interpretarse como capturas contemporáneas de la explotación ni como certificación independiente de los comandos ejecutados.

Figura B-1. Escaneo Basic Pentesting — Nmap

```
kali@kali: ~/TP_THM
Session Actions Edit View Help
# Nmap done at Thu Oct 8 12:34:09 2026 -- 1 IP address (1 host up) scanned in 1105.73 seconds

kali@kali:~/TP_THM
$ ls -la evidencias/
total 24
drwxrwxr-x 6 kali kali 4096 Oct 8 12:03 .
drwxrwxr-x 6 kali kali 4096 Oct 8 12:03 ..
drwxrwxr-x 2 kali kali 4096 Oct 8 12:03 escaneo
drwxrwxr-x 2 kali kali 4096 Oct 8 12:03 explotacion
drwxrwxr-x 2 kali kali 4096 Oct 8 12:03 post
drwxrwxr-x 2 kali kali 4096 Oct 8 12:03 reconocimiento

kali@kali:~/TP_THM
$ find ~/Pictures ~/Desktop ~/tp_tryhackme -type f \( -iname '*.png' -o -iname '*.jpg' -o -iname '*.jpeg' \) 2>/dev/null

kali@kali:~/TP_THM
$ cat ~/TP_THM/bitacora/nmap_inicial.txt
# Nmap 7.99 scan initiated Wed Oct 7 21:36:44 2026 as: /usr/lib/nmap/nmap --privileged -sC -sV -oN /home/kali/tp_tryhackme/bitacora/nmap_inicial.txt 10.64.138.62
Nmap scan report for 10.64.138.62
Host is up (0.16s latency).
Not shown: 994 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   3072 64:6b:08:fa:fb:db:bb:9f:78:1c:3f:da:a8:2a:c3:77 (RSA)
|   256 77:a2:ae:1e:cf:ab:8a:5e:0e:b5:5b:5f:78:f2:ad:c9 (ECDSA)
|_ 256 6c:c2:ab:ce:e1:e7:9f:48:e3:05:34:96:5b:e5:05:39 (ED25519)
80/tcp    open  http         Apache httpd 2.4.41 ((Ubuntu))
|_ http-title: Site doesn't have a title (text/html).
|_ http-server-header: Apache/2.4.41 (Ubuntu)
139/tcp   open  netbios-ssn  Samba smbd 4
445/tcp   open  netbios-ssn  Samba smbd 4
8080/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
|_ ajp-methods:
|_ Supported methods: GET HEAD POST OPTIONS
8080/tcp  open  http         Apache Tomcat/9.0.7
|_ http-favicon: Apache Tomcat
|_ http-title: Apache Tomcat/9.0.7
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_ smb2-security-mode:
|   3.1.1:
|_ Message signing enabled but not required
|_ smb2-time:
|_ date: 2026-10-08T01:37:07
|_ start_date: N/A
|_ clock-skew: 4s
|_ nbstat: NetBIOS name: BASIC2, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
# Nmap done at Wed Oct 7 21:37:07 2026 -- 1 IP address (1 host up) scanned in 22.82 seconds

kali@kali:~/TP_THM
$ xfce4-screenshooter -w -d 3
```

Registro original: bitacora/nmap_inicial.txt. IP efímera: 10.64.138.62.

Figura B-2. Escaneo Vulniversity — Nmap

```
kali@kali: ~/TP_THM
Session Actions Edit View Help
22/tcp open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_ 3072 64:6b:08:f4:fb:d4:bb:9f:70:1c:3f:da:a0:72:a:c3:77 (RSA)
|_ 256 77:a2:3e:1e:cf:ab:0a:5e:0e:b5:50:5f:76:f2:ad:c9 (ECDSA)
|_ 256 6c:c2:ab:ce:1e:79:f4:8e:34:09:34:90:5b:a3:03:19 (ED25519)
80/tcp open  http      Apache httpd 2.4.41 ((Ubuntu))
|_ http-title: Site doesn't have a title (text/html).
|_ http-server-header: Apache/2.4.41 (Ubuntu)
139/tcp open  netbios-ssn Samba smbd 4
445/tcp open  netbios-ssn Samba smbd 4
8080/tcp open  ajp13     Apache Jserv (Protocol v1.3)
|_ ajp-methods:
|_ Supported methods: GET HEAD POST OPTIONS
8080/tcp open  http      Apache Tomcat 9.0.7
|_ http-favicon: Apache Tomcat
|_ http-title: Apache Tomcat/9.0.7
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_ smb2-security-mode:
|_ 3.1.1:
|_ Message signing enabled but not required
|_ smb2-time:
|_ date: 2026-10-08T01:37:07
|_ start_date: N/A
|_ clock-skew: 4s
|_ nbstat: NetBIOS name: BASIC2, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
# Nmap done at Wed Oct 7 21:37:07 2026 -- 1 IP address (1 host up) scanned in 22.82 seconds

(kali@kali)~(~/TP_THM)
$ xfce4-screenshooter -w -d 3

(kali@kali)~(~/TP_THM)
$ ls -lh ~/TP_THM/evidencias/escaneo/
total 204K
-rw-rw-r-- 1 kali kali 204K Oct 8 12:43 escaneo_H01.png

(kali@kali)~(~/TP_THM)
$ cat ~/TP_THM/bitacora/vulniversity_nmap.txt
# nmap 7.99 Scan initiated Thu Oct 8 12:15:44 2026 as: /usr/lib/nmap/nmap -Pn -sV -p- -oN bitacora/vulniversity_nmap.txt 10.65.161.75
Nmap scan report for 10.65.161.75
Host is up (0.16s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
3128/tcp  open  http-proxy  Squid http proxy 4.10
3333/tcp  open  http        Apache httpd 2.4.41 ((Ubuntu))

Read data files from: /usr/share/nmap
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
# Nmap done at Thu Oct 8 12:34:09 2026 -- 1 IP address (1 host up) scanned in 1105.73 seconds

(kali@kali)~(~/TP_THM)
$ xfce4-screenshooter -w -d 3
```

Registro original: bitacora/vulniversity_nmap.txt. IP efímera: 10.65.161.75.

Figura B-3. Enumeración web Basic Pentesting — Gobuster

```
Session Actions Edit View Help
Host script results:
| smb2-security-mode:
|   3.1.1:
|     Message signing enabled but not required
|_
|_ smb2-time:
|   date: 2026-10-08T01:37:07
|_ start_date: N/A
|_ smb2-keep: 4s
|_ smbstat: NetBIOS name: BASIC2, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
# Nmap done at Wed Oct  7 21:37:07 2026 -- 1 IP address (1 host up) scanned in 22.82 seconds

(kali@kali)-[~/TP_THM]
$ xfce4-screenshooter -w -d 3

(kali@kali)-[~/TP_THM]
$ ls -lh ~/TP_THM/evidencias/escaneo/
total 204K
-rw-rw-r-- 1 kali kali 204K Oct  8 12:43 escaneo_H01.png

(kali@kali)-[~/TP_THM]
$ cat ~/TP_THM/bitacora/vulnversity_nmap.txt
# Nmap 7.99 scan initiated Thu Oct  8 12:15:44 2026 as: /usr/lib/nmap/nmap -Pn -p- -oN bitacora/vulnversity_nmap.txt 10.65.161.75
Nmap scan report for 10.65.161.75
Host is up (0.16s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
3128/tcp  open  http-proxy Squid http proxy 4.10
3333/tcp  open  http      Apache httpd 2.4.41 ((Ubuntu))

Read data files from: /usr/share/nmap
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
# Nmap done at Thu Oct  8 12:34:09 2026 -- 1 IP address (1 host up) scanned in 1185.73 seconds

(kali@kali)-[~/TP_THM]
$ xfce4-screenshooter -w -d 3

(kali@kali)-[~/TP_THM]
$ ls -lh ~/TP_THM/evidencias/escaneo/
total 428K
-rw-rw-r-- 1 kali kali 204K Oct  8 12:43 escaneo_H01.png
-rw-rw-r-- 1 kali kali 222K Oct  8 12:48 escaneo_H02.png

(kali@kali)-[~/TP_THM]
$ cat ~/TP_THM/bitacora/gobuster.txt
.htaccess      (Status: 403) [Size: 277]
.hta           (Status: 403) [Size: 277]
.htpasswd      (Status: 403) [Size: 277]
development    (Status: 301) [Size: 318] [→ http://10.64.138.62/development/]
index.html     (Status: 200) [Size: 158]
server-status  (Status: 403) [Size: 277]
```

Registro original: bitacora/gobuster.txt. Hallazgo de /development/.

Correspondencia: el rótulo H03/H04 del archivo de imagen designa la secuencia de capturas, no el ID de hallazgo H-03/H-04 del informe.

Figura B-4. Enumeración web Vulniversity — Gobuster

```
kali@kali: ~/TP_THM
Session Actions Edit View Help
kali@kali:~/TP_THM/
$ ls -lh ~/TP_THM/evidencias/escaneo/
total 204K
-rw-rw-r-- 1 kali kali 204K Oct  8 12:43 escaneo_H01.png

kali@kali:~/TP_THM/
$ cat ~/TP_THM/bitacora/vulniversity_nmap.txt
# Nmap 7.99 Scan Initiated Thu Oct  8 12:15:44 2026 as: /usr/lib/nmap/nmap -Pn -SV -p- -oN bitacora/vulniversity_nmap.txt 10.65.161.75
# Nmap scan report for 10.65.161.75
Host is up (0.16s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
3128/tcp  open  http-proxy Squid http proxy 4.10
3333/tcp  open  http      Apache httpd 2.4.41 ((Ubuntu))

Read data files from: /usr/share/nmap
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
# Nmap done at Thu Oct  8 12:34:09 2026 -- 1 IP address (1 host up) scanned in 1105.73 seconds

kali@kali:~/TP_THM/
$ xfce4-screenshooter -w -d 3

kali@kali:~/TP_THM/
$ ls -lh ~/TP_THM/evidencias/escaneo/
total 428K
-rw-rw-r-- 1 kali kali 204K Oct  8 12:43 escaneo_H01.png
-rw-rw-r-- 1 kali kali 222K Oct  8 12:48 escaneo_H02.png

kali@kali:~/TP_THM/
$ cat ~/TP_THM/bitacora/gobuster.txt
.htaccess      (Status: 403) [Size: 277]
.hta           (Status: 403) [Size: 277]
.htpasswd      (Status: 403) [Size: 277]
development    (Status: 301) [Size: 318] [→ http://10.64.138.62/development/]
index.html     (Status: 200) [Size: 158]
server-status  (Status: 403) [Size: 277]

kali@kali:~/TP_THM/
$ xfce4-screenshooter -w -d 3

kali@kali:~/TP_THM/
$ cat ~/TP_THM/bitacora/vulniversity_gobuster.txt
.hta           (Status: 403) [Size: 280]
.htaccess      (Status: 403) [Size: 280]
.htpasswd      (Status: 403) [Size: 280]
css            (Status: 301) [Size: 319] [→ http://10.64.171.119:3333/css/]
fonts          (Status: 301) [Size: 321] [→ http://10.64.171.119:3333/fonts/]
images         (Status: 301) [Size: 322] [→ http://10.64.171.119:3333/images/]
index.html     (Status: 200) [Size: 33014]
internal       (Status: 301) [Size: 324] [→ http://10.64.171.119:3333/internal/]
js             (Status: 301) [Size: 318] [→ http://10.64.171.119:3333/js/]
server-status  (Status: 403) [Size: 280]

kali@kali:~/TP_THM/
$ xfce4-screenshooter -w -d 3
```

Registro original: bitacora/vulniversity_gobuster.txt. Hallazgo de /internal/. IP efímera distinta por sesión.

Correspondencia: el rótulo H03/H04 del archivo de imagen designa la secuencia de capturas, no el ID de hallazgo H-03/H-04 del informe.

ANEXO C — TRAZABILIDAD Y PENDIENTES

Origen de los registros

Los resultados técnicos verificables incluidos en el ZIP son los archivos `nmap_inicial.txt`, `vulnversity_nmap.txt`, `gobuster.txt` y `vulnversity_gobuster.txt`. Las fichas `vulnversity_hallazgo.txt` y `vulnversity_escalada.txt` son descripciones realizadas con posterioridad a la práctica.

Evidencia no adjunta

Los hallazgos relativos a Hydra, SMB anónimo, clave privada SSH, Burp Intruder, shell `www-data` y ejecución de servicio como root fueron descritos durante la práctica, pero el ZIP no contiene capturas originales ni transcripciones brutas de esas acciones. El nivel de corroboración de dichos hechos debe entenderse como relato documentado, no como evidencia audiovisual archivada.

El escaneo de Vulnversity usó 10.65.161.75, mientras que el registro Gobuster usa 10.64.171.119. Ambas son direcciones efímeras de sesiones distintas y no se debe afirmar que son el mismo servidor activo simultáneamente.

Revisión de secretos

Se revisó el contenido textual del ZIP contra patrones comunes de secretos y no se identificaron contraseñas, tokens ni claves privadas. Esta comprobación no sustituye una revisión humana antes de la publicación.

ANEXO D - VALIDACIÓN DE RESULTADOS

Root flag de Vulniversity: valor original omitido por seguridad.

SHA-256 calculado por el estudiante en Kali (Zsh):

c fbc740435ad60030304080e35131ffcaf8ac5f71b65e002f5b546aa3cda7ce8

Basic Pentesting: las preguntas de la sala figuran como respuestas correctas.

El valor final obtenido es una contraseña, no una root flag.

No publicar ni adjuntar la contraseña en texto claro.

Verificaciones documentadas:

- Nmap Basic Pentesting: bitacora/nmap_inicial.txt
- Nmap Vulniversity: bitacora/vulniversity_nmap.txt
- Enumeración web: bitacora/gobuster.txt y vulniversity_gobuster.txt
- Explotación y escalada: fichas descriptivas, no capturas contemporáneas.

Validación administrativa pendiente:

- Firma manuscrita o digital válida en la declaración ética.
- Confirmar la identidad visible en capturas críticas según la cátedra.
- Comprobar que las bitácoras y las imágenes no revelen secretos.